

C04-AT3

CASE-STUDY

Q1. E-Commerce Web Server Security Assessment

1. Introduction

The e-commerce company hosts its web application on an Apache web server running on Linux. Customers have reported unauthorized transactions and abnormal account activity. Investigation has identified suspicious HTTP requests, attempts to access hidden directories, malicious scripts submitted through input fields, an outdated Apache version, and the absence of a Web Application Firewall (WAF).

The incident indicates a combination of **web-server vulnerabilities, inadequate input validation, outdated software, insufficient application security, and lack of network-level protection**. A comprehensive assessment using Kali Linux should identify and validate these weaknesses within an authorized testing environment and then implement layered security controls.

2. Case Analysis

The suspected attack chain is:

Reconnaissance → Web-server discovery → Directory enumeration → Vulnerability identification → Input manipulation → Exploitation → Account compromise/unauthorized transactions

The attacker may have first identified the Apache server and its version, searched for hidden resources, examined application inputs, and then attempted injection attacks. An outdated server could provide additional opportunities if known vulnerabilities are present.

3. Possible Attack Vectors

3.1 Outdated Apache Server

Running an outdated Apache version can expose the organization to publicly documented vulnerabilities.

Risk: High

An attacker may identify the server version using service enumeration and compare it against known security advisories.

Recommendation: Upgrade Apache and all associated packages to supported, patched versions and establish a regular patch-management process.

3.2 Hidden Directories and Files

The suspicious requests for hidden directories suggest directory enumeration.

Potentially exposed resources could include:

- Administrative pages
- Backup files
- Configuration files

- Development directories
- Old application versions
- Log files

Risk: High

Sensitive files should never be accessible through the public web root.

3.3 Input Validation Vulnerabilities

Malicious scripts inserted into input fields indicate a possible **Cross-Site Scripting (XSS)** vulnerability.

Risk: High

If user input is displayed without proper output encoding, malicious content could execute in another user's browser.

Recommendation: Validate input, encode output according to its context, implement appropriate Content Security Policy controls, and avoid directly inserting untrusted data into HTML or JavaScript.

3.4 Authentication and Account Abuse

Unauthorized transactions and abnormal account activity may indicate compromised accounts or weaknesses in authentication and session management.

Risk: Critical

Potential weaknesses include:

- Weak passwords
- Missing multi-factor authentication
- Poor session management
- Long-lived sessions
- Missing account-lockout/rate-limiting controls
- Insufficient transaction verification

3.5 Missing Web Application Firewall

The organization does not have a WAF.

Risk: High

A WAF can provide an additional layer of protection against common web attacks such as injection attempts, malicious requests, and abnormal application traffic.

A WAF should **not** be considered a replacement for secure coding and server hardening.

4. Reconnaissance Methodology

Testing should begin with passive and low-impact reconnaissance against the authorized laboratory target.

Nmap

Service discovery can be performed using:

```
nmap -sV <AUTHORIZED-LAB-IP>
```

A more detailed authorized assessment can use:

```
nmap -sC -sV <AUTHORIZED-LAB-IP>
```

The purpose is to identify open ports, running services, and service versions.

WhatWeb

The web technology stack can be identified using:

```
whatweb http://<AUTHORIZED-LAB-IP>
```

This can reveal technologies such as Apache, PHP, JavaScript frameworks, and other application components.

Curl

HTTP headers can be examined with:

```
curl -I http://<AUTHORIZED-LAB-IP>
```

The analyst should examine headers such as:

- Server
- X-Powered-By
- Set-Cookie
- Content-Security-Policy
- X-Frame-Options
- X-Content-Type-Options
- Strict-Transport-Security

Unnecessary version disclosure should be minimized.

5. Vulnerability Scanning

Nikto

Nikto can be used to identify common web-server misconfigurations and potentially exposed resources:

```
nikto -h http://<AUTHORIZED-LAB-IP>
```

The output should be treated as an initial source of findings. Important findings must be manually validated before being classified as confirmed vulnerabilities.

Gobuster

Directory and file enumeration can be performed against the authorized lab target:

```
gobuster dir -u http://<AUTHORIZED-LAB-IP> -w /usr/share/wordlists/dirb/common.txt
```

If the assessment permits common file-extension discovery:

```
gobuster dir -u http://<AUTHORIZED-LAB-IP> -w /usr/share/wordlists/dirb/common.txt -x php,html,txt,bak
```

Discovered administrative or backup resources should be checked only within the authorized environment.

6. Web Application Testing

The application's forms and parameters should be examined using **Burp Suite** or **OWASP ZAP**.

The tester should identify:

- Login parameters
- Search fields
- Registration forms
- Transaction parameters
- Cookies
- Session identifiers
- URL parameters
- POST parameters
- API requests

The objective is to determine whether untrusted input is properly validated and whether authentication and authorization controls are correctly implemented.

Potential XSS or injection findings should be validated using **non-destructive test inputs** in the laboratory rather than attempting to extract real customer information or modify transactions.

7. Exploitation and Validation

Exploitation should only be performed against the faculty-approved vulnerable laboratory system.

The validation process should follow:

Identify → Form hypothesis → Send controlled test input → Observe response → Confirm vulnerability → Document evidence → Stop

For example, if an input field appears vulnerable to XSS, the tester should use a harmless proof-of-concept in the isolated laboratory environment and determine whether the application treats the input as executable content or safely encodes it.

Similarly, an outdated Apache finding should be validated by confirming the exact version and checking whether the identified version is affected by a relevant security advisory. The presence of an old version alone should not automatically be reported as an exploitable vulnerability.

8. Impact Analysis

Finding	Likelihood	Impact	Severity
Outdated Apache/software	High	High	High
XSS/input validation weakness	High	High	High

Exposed sensitive directories/files	Medium–High	High	High
Weak authentication/session controls	Medium–High	Critical	Critical
Missing WAF	Medium	High	Medium–High
Excessive server information disclosure	Medium	Medium	Medium

9. CIA Triad Analysis

Confidentiality

Attackers may gain access to customer accounts, personal information, payment-related information, or internal server data.

Integrity

Unauthorized account access could allow attackers to modify customer profiles, orders, or transactions.

Availability

Exploitation of server vulnerabilities or malicious application activity could disrupt web services and affect customers' ability to access their accounts.

Therefore, the incident potentially affects **all three elements of the CIA triad**, with confidentiality and integrity being particularly important because unauthorized transactions have already been reported.

10. Layered Defense Strategy

Layer 1 – Server Hardening

- Update Apache and Linux packages.
- Remove unnecessary services.
- Disable unnecessary modules.
- Hide unnecessary server-version information.
- Apply secure file and directory permissions.
- Disable directory listing where unnecessary.
- Remove backup and development files from the web root.

Layer 2 – Secure Coding

Developers should:

- Validate all input.
- Use parameterized database queries.
- Encode output.
- Implement secure session management.
- Apply server-side authorization checks.

- Avoid exposing detailed database/server errors.
- Implement transaction validation.

Layer 3 – Authentication Security

- Use strong password policies.
- Implement MFA.
- Apply login rate limiting.
- Detect abnormal account activity.
- Secure session cookies using appropriate security attributes.
- Expire inactive sessions.
- Require additional verification for sensitive transactions.

Layer 4 – Network Protection

Deploy:

- Web Application Firewall
- Network firewall
- IDS/IPS
- Network segmentation
- Centralized logging
- SIEM monitoring

The WAF should detect and block suspicious web traffic while allowing legitimate application requests.

Layer 5 – Monitoring and Incident Response

Security teams should continuously monitor:

- HTTP access logs
- Authentication logs
- WAF events
- Database activity
- Administrative actions
- Unusual transaction patterns
- Repeated failed requests
- Requests for sensitive directories

Alerts should be generated for suspicious behavior and investigated promptly.

11. Recommended Security Architecture

A layered architecture can be represented as:

Internet



Firewall



WAF



Load Balancer / Web Server



Application Server



Database Server

The database should not be directly accessible from the Internet. Network segmentation and firewall rules should restrict communication between each layer.

12. Risk Prioritization

The highest priority should be given to weaknesses that could directly lead to unauthorized transactions or compromise of customer accounts.

Critical Priority

- Authentication/session weaknesses
- Vulnerabilities exposing payment or customer information

High Priority

- Outdated Apache/software
- XSS and input-validation weaknesses
- Exposed sensitive directories/files
- Insufficient access controls

Medium Priority

- Server information disclosure
- Missing additional security headers
- Other non-critical configuration weaknesses

13. Conclusion

The e-commerce incident appears to result from multiple weaknesses operating together rather than a single vulnerability. The outdated Apache server increases exposure to known vulnerabilities, while inadequate input validation may allow attacks such as XSS. Hidden directories and files can expose sensitive resources, and weak authentication or session controls can contribute directly to unauthorized account activity and transactions.

A strong defense requires multiple layers: **patched and hardened servers, secure application development, strong authentication, proper session management, network segmentation, WAF protection, continuous monitoring, and an effective incident-response process.** Regular vulnerability assessments and penetration tests should also be conducted in an authorized environment to identify weaknesses before attackers can exploit them.

14. Final Assessment

Overall Risk: HIGH to CRITICAL

The combination of outdated software, application-level input-validation weaknesses, suspicious web requests, and lack of WAF protection creates a significant attack surface. Immediate patching, secure coding improvements, stronger authentication, WAF deployment, network segmentation, and centralized security monitoring are recommended to reduce the likelihood of future compromise.

Q2. Financial Web Application Security Assessment

1. Introduction

The financial services web application allows customers to log in, view account information, and perform financial transactions. A penetration test has identified **SQL Injection (SQLi)** and **Cross-Site Scripting (XSS)** vulnerabilities. The application also exposes database-related information through error messages and does not properly sanitize user input.

These weaknesses create serious risks because an attacker may manipulate database queries, access sensitive customer information, or inject malicious content into pages viewed by other users. This assessment explains how the vulnerabilities can be identified and safely validated using Kali Linux tools such as **Burp Suite** and **SQLmap**, evaluates their impact on the CIA triad, and proposes comprehensive remediation measures.

2. Case Analysis

The likely attack chain is:

Reconnaissance → Identify input parameters → Intercept HTTP request → Test input validation → Identify SQL Injection/XSS → Safely validate → Assess impact → Remediate

The combination of database errors, unsanitized input, and financial functionality makes this application a high-risk target.

3. SQL Injection

SQL Injection occurs when untrusted user input is incorporated into a database query without proper parameterization.

For example, an insecure application might construct a query conceptually like:

```
SELECT * FROM accounts WHERE username = '<user_input>';
```

If the application directly inserts untrusted input into the query, an attacker may manipulate the intended query structure.

Security Impact

A successful SQL injection can potentially allow:

- Unauthorized database access

- Exposure of customer information
- Modification of database records
- Authentication bypass
- Extraction of sensitive information
- Destruction or disruption of database contents

Severity: Critical

4. XSS

Cross-Site Scripting occurs when an application accepts untrusted input and later places it into a web page without appropriate output encoding.

In this case, an attacker could potentially inject malicious script content into a page that other users subsequently view.

Potential consequences include:

- Session compromise
- Unauthorized actions performed through a victim's browser
- Theft of sensitive information accessible to the browser
- Website content manipulation
- Phishing within the trusted application interface

Severity: High

5. Reconnaissance

The first stage of the assessment is to identify the application's attack surface.

Nmap

Against the authorized laboratory target:

```
nmap -sV <AUTHORIZED-LAB-IP>
```

This identifies exposed services and versions.

WhatWeb

```
whatweb http://<AUTHORIZED-LAB-URL>
```

This can identify technologies such as Apache, PHP, frameworks, and other components.

Curl

```
curl -I http://<AUTHORIZED-LAB-URL>
```

The response headers can reveal information about the application and its security configuration.

6. Burp Suite Methodology

Burp Suite can be used as an HTTP interception proxy for the authorized laboratory application.

Step 1 – Configure the Browser

Configure the browser to use Burp Suite's local proxy.

Step 2 – Browse the Application

Open the test application and perform normal actions such as:

- Login using the provided test account.
- Open the account page.
- View a test transaction.
- Submit an authorized test form.

Step 3 – Capture Requests

Burp Proxy can capture requests generated by the application.

Identify:

- URL parameters
- POST parameters
- Cookies
- Session identifiers
- Form fields
- API requests
- Hidden parameters

Step 4 – Send Interesting Requests to Repeater

A selected request can be sent to **Repeater** for controlled testing.

The tester can modify one parameter at a time and compare:

Original request → Modified request → Server response

This makes it easier to determine whether user input is being safely handled.

7. SQL Injection Validation

SQL injection should only be validated against the authorized vulnerable laboratory application.

A safe methodology is:

1. Identify an input parameter.
2. Send the normal request.
3. Modify the parameter with controlled test input.
4. Compare the server response.
5. Observe whether database-related errors or unexpected behavior occur.
6. Determine whether the behavior is consistent.
7. Confirm the finding without extracting unnecessary real data.

SQLmap

SQLmap can assist with automated SQL injection detection against an authorized test application.

For a captured request saved by Burp Suite:

```
sqlmap -r request.txt --batch
```

The request.txt file should contain the **authorized laboratory request** captured during testing.

A focused test can be performed only against the identified parameter:

```
sqlmap -r request.txt -p <TEST_PARAMETER> --batch
```

The objective for an assessment is to determine whether SQL injection exists and document the evidence. Avoid unnecessary dumping of sensitive information.

8. XSS Validation

XSS testing should also be performed only against the authorized test application.

The methodology is:

1. Identify parameters that accept user-controlled data.
2. Submit harmless test content.
3. Observe whether the application reflects or stores the input.
4. Determine whether the output is correctly encoded.
5. Verify whether the browser interprets the content as executable markup/script.
6. Document the vulnerable parameter and affected page.

A confirmed finding should distinguish between:

- **Reflected XSS** – input is immediately reflected in the response.
- **Stored XSS** – malicious input is stored and displayed to other users.
- **DOM-based XSS** – client-side JavaScript processes unsafe input.

For this financial application, stored XSS can be particularly serious because malicious content could potentially be displayed to multiple authenticated users.

9. Error-Message Information Disclosure

The application exposes database structure information through error messages.

Severity: Medium–High

Detailed database errors can help attackers understand:

- Database type
- Table names
- Column names
- Query structure
- Application framework

- File paths

Recommendation

Production applications should display generic error messages to users while recording detailed technical errors securely in server-side logs.

Instead of exposing database errors, the application should return a message such as:

An unexpected error occurred. Please try again later.

Detailed diagnostic information should remain accessible only to authorized administrators.

10. CIA Triad Analysis

Confidentiality

SQL injection could expose customer account information and database records. XSS could potentially expose sensitive information accessible through an affected user's browser session.

Impact: Critical

Integrity

SQL injection could potentially modify financial or customer records if sufficient database privileges exist. XSS could enable unauthorized actions through a victim's browser.

Impact: Critical

Availability

Poorly controlled injection attacks may cause database errors, application failures, or service disruption.

Impact: High

Therefore, the vulnerabilities affect **confidentiality, integrity, and availability**.

11. Risk Assessment

Vulnerability	Likelihood	Impact	Severity
SQL Injection	High	Critical	Critical
Stored XSS	High	High/Critical	High/Critical
Reflected XSS	Medium–High	High	High
Database error disclosure	High	Medium	Medium
Weak input validation	High	High	High
Weak session protection	Medium–High	High	High

12. SQL Injection Mitigation

The primary defense against SQL injection is **parameterized queries/prepared statements**.

Instead of constructing SQL statements through string concatenation, applications should use parameter binding provided by the database framework.

Additional controls include:

- Server-side input validation
- Least-privilege database accounts
- Separation of database accounts by application function
- Secure error handling
- Regular code review
- SAST/DAST testing
- Database activity monitoring

Input validation should be considered an additional layer, not the primary defense.

13. XSS Mitigation

The application should implement **context-aware output encoding**.

Recommended controls include:

- HTML encoding
- JavaScript-context encoding
- URL encoding where appropriate
- Safe DOM APIs
- Avoiding unsafe HTML insertion
- Content Security Policy
- Secure cookie attributes
- Input validation

A Content Security Policy can provide an additional layer of protection against script execution.

14. Secure Session Management

Because this is a financial application, session security is particularly important.

Recommended controls include:

- Secure cookies
- HttpOnly cookies
- Appropriate SameSite settings
- Session ID regeneration after login
- Short session timeouts for sensitive operations
- Secure logout and session invalidation
- MFA
- Re-authentication for high-risk transactions

- Detection of unusual account activity

15. Layered Security Controls

The recommended defense-in-depth architecture includes:

User

↓

HTTPS/TLS

↓

WAF

↓

Web Application

↓

Secure Application Code

↓

Parameterized Database Queries

↓

Restricted Database

Additional protection should include:

- IDS/IPS
- SIEM
- Endpoint monitoring
- Vulnerability management
- Secure development lifecycle
- Regular penetration testing

16. Testing and Validation Process

The assessment should follow:

**Reconnaissance → Identify Parameters → Intercept Request → Test → Validate → Document
→ Remediate → Retest**

Each vulnerability should be classified as:

- **Confirmed**
- **False Positive**
- **Requires Further Investigation**

Automated scanner output should not be accepted as proof without manual validation.

17. Overall Risk Rating

Overall Severity: Critical

The presence of SQL injection in a financial application represents a particularly serious risk because the application handles sensitive customer and transaction information. XSS further increases the risk of account compromise and unauthorized actions.

18. Conclusion

The financial web application contains multiple weaknesses that can be exploited through improper input handling. SQL injection can potentially compromise database confidentiality and integrity, while XSS can affect users through malicious content executed in their browsers. Detailed database error messages further assist attackers during reconnaissance.

Burp Suite can be used to intercept and analyze application requests, while SQLmap can assist in safely identifying SQL injection within the authorized laboratory environment. The most important remediation measures are **parameterized queries, context-aware output encoding, secure session management, strong authentication, generic error handling, WAF protection, continuous monitoring, and regular security testing.**

Implementing these controls as a layered defense will significantly reduce the likelihood of successful attacks and protect the confidentiality, integrity, and availability of customer and financial information.

Q3. Evil Twin Attack and Wireless Security Assessment

1. Introduction

The corporate office provides wireless access to employees using **WPA2-PSK** authentication. Employees have reported unusual login prompts and poor network performance. Investigation revealed a **rogue access point (Evil Twin)** that was using the same SSID as the legitimate corporate Wi-Fi network.

The attacker used the fraudulent access point to trick employees into connecting to it, capture credentials, and potentially perform **Man-in-the-Middle (MITM)** attacks. This case demonstrates weaknesses in wireless authentication, access-point monitoring, user awareness, and network configuration.

2. Case Analysis

The suspected attack chain is:

Rogue AP Setup → Same SSID as Corporate Wi-Fi → Employee Connects → Fake Login/Captive Portal → Credential Capture → MITM → Possible Account/Network Compromise

The attacker takes advantage of the fact that users often identify a Wi-Fi network by its **SSID alone**. If the legitimate network does not provide strong authentication and certificate validation, users may connect to a malicious access point without realizing it.

3. How the Evil Twin Attack Works

An Evil Twin is a fraudulent wireless access point designed to imitate a legitimate access point.

The attacker may:

1. Identify the corporate SSID.
2. Create a rogue access point using the same or a similar SSID.
3. Position the rogue AP where employees can receive a strong signal.
4. Attempt to attract clients to the rogue AP.
5. Present a fraudulent login page or network authentication prompt.
6. Capture credentials entered by unsuspecting users.
7. Potentially intercept or manipulate traffic.
8. Use stolen credentials for further unauthorized access.

The attack becomes more dangerous when employees trust the network simply because the SSID appears familiar.

4. Wireless Security Weaknesses

4.1 WPA2-PSK

The organization uses a shared WPA2-PSK password.

Severity: High

A shared password creates several problems:

- Employees may share the password.
- Former employees may still know it.
- The same key may be used across many devices.
- Compromise of the PSK can affect the entire wireless network.

Recommendation: Use **WPA2-Enterprise** or **WPA3-Enterprise** with individual user/device authentication.

4.2 Lack of Rogue AP Detection

The presence of an Evil Twin indicates inadequate wireless monitoring.

Severity: High

Recommendation: Deploy a **Wireless Intrusion Detection/Prevention System (WIDS/WIPS)** to detect unauthorized access points and suspicious wireless activity.

4.3 Weak Authentication

If users can connect without validating the identity of the legitimate authentication server, attackers may impersonate the network.

Severity: High

Enterprise authentication using **802.1X/RADIUS** and certificate validation provides significantly stronger protection.

4.4 Credential Capture

The fake login page can trick employees into entering usernames and passwords.

Severity: Critical

Compromised credentials could allow attackers to access corporate applications if the same credentials are reused elsewhere.

Recommendation:

- Implement MFA.
- Educate users about fraudulent login prompts.
- Never trust unexpected authentication pages.
- Use certificate-based enterprise authentication where appropriate.

5. Kali Linux Tools for Detection and Analysis

Testing must be performed only against the **faculty-authorized laboratory wireless network**.

5.1 Aircrack-ng

The Aircrack-ng suite can be used by security teams to inspect wireless networks and identify access points.

For example, in an authorized lab, wireless interfaces can be identified using:

`iwconfig`

Available wireless interfaces can then be examined.

Aircrack-ng tools can help security analysts observe:

- SSIDs
- BSSIDs/MAC addresses
- Channels
- Signal strength
- Encryption type
- Authentication method

The analyst can compare the legitimate AP's characteristics against suspected rogue APs.

5.2 Airodump-ng

In an authorized laboratory environment, Airodump-ng can be used to monitor nearby wireless traffic:

`sudo airodump-ng <MONITOR_INTERFACE>`

The output can help identify:

- Multiple APs advertising the same SSID
- Unexpected BSSIDs
- Different channels
- Signal-strength differences
- Unrecognized wireless devices

A suspicious finding would be **the same corporate SSID appearing with an unauthorized BSSID**.

6. Wireshark Analysis

Wireshark can be used to analyze captured wireless traffic where the test environment and hardware support appropriate capture.

The analyst should look for:

- Repeated authentication activity
- Unexpected HTTP traffic
- DNS anomalies
- Connections to unknown hosts
- Suspicious authentication pages
- Unusual ARP behavior
- Unexpected network destinations

For example, HTTP traffic can be examined using:

http

as a Wireshark display filter.

DNS activity can be examined using:

dns

The objective is to identify suspicious traffic patterns, not to collect real employee credentials.

7. Identifying the Evil Twin

The following characteristics can help identify a rogue AP:

Legitimate AP

Approved BSSID

Authorized channel

Expected security configuration

Suspicious AP

Unknown BSSID

Unexpected channel

Different security configuration

Known infrastructure

Unknown device

Expected certificate/authentication Suspicious login prompt

Normal signal behavior

Unusual signal strength/location

An SSID alone should **not** be used to determine whether a wireless network is legitimate.

8. MITM Risk

Once a victim connects to a malicious access point, the attacker may attempt to position themselves between the victim and the Internet.

Potential consequences include:

- Credential theft
- Traffic interception
- DNS manipulation
- Malicious redirection
- Session compromise
- Phishing
- Malware delivery

However, properly configured **HTTPS/TLS** significantly reduces the ability of an attacker to read protected application traffic.

9. CIA Triad Analysis

Confidentiality

Captured credentials and improperly protected traffic may expose sensitive corporate information.

Impact: Critical

Integrity

A MITM attacker may attempt to modify unprotected traffic or redirect users toward malicious resources.

Impact: High

Availability

Rogue APs and wireless interference can cause employees to experience slow connections or loss of connectivity.

Impact: High

Therefore, the Evil Twin attack can affect **confidentiality, integrity, and availability**.

10. Recommended Security Architecture

The organization should migrate from shared WPA2-PSK authentication to:

Employee Device

↓

WPA2-Enterprise / WPA3-Enterprise

↓

802.1X Authentication

↓

RADIUS Server

↓

Corporate Network

Different users should receive individual authentication rather than sharing one wireless password.

11. Network Segmentation

Wireless access should be separated according to user and device type.

Example:

Employee Wi-Fi VLAN

→ Corporate applications

Guest Wi-Fi VLAN

→ Internet only

IoT VLAN

→ Restricted services

Management VLAN

→ Network administration only

Firewalls and access-control rules should prevent unnecessary communication between these networks.

12. Strong Countermeasures

Technical Controls

1. Replace WPA2-PSK with **WPA2-Enterprise or WPA3-Enterprise**.
2. Use 802.1X/RADIUS authentication.
3. Use certificate-based authentication where appropriate.
4. Enable strong certificate validation on managed devices.

5. Deploy WIDS/WIPS.
6. Maintain an inventory of authorized access points.
7. Monitor for duplicate SSIDs.
8. Segment employee and guest networks.
9. Enforce HTTPS/TLS.
10. Implement MFA for corporate applications.
11. Monitor DNS and network traffic.
12. Use centralized logging and SIEM.

Administrative Controls

- Establish a wireless-security policy.
- Regularly audit wireless infrastructure.
- Remove unauthorized APs.
- Review employee access regularly.
- Change credentials when necessary.
- Maintain an incident-response procedure.

13. User Awareness

Employees are an important layer of defense.

Users should be trained to:

- Avoid connecting to unknown Wi-Fi networks.
- Report unexpected login prompts.
- Verify certificate warnings instead of ignoring them.
- Avoid entering corporate credentials into suspicious pages.
- Use corporate VPN when required.
- Report unusual Wi-Fi behavior.
- Never assume that a familiar SSID is automatically legitimate.

Regular phishing and wireless-security awareness training should be conducted.

14. Risk Assessment

Finding	Likelihood	Impact	Severity
Evil Twin / Rogue AP	High	Critical	Critical
Shared WPA2-PSK	High	High	High

Credential capture	High	Critical	Critical
Lack of WIDS/WIPS	High	High	High
MITM opportunity	Medium–High	High	High
Poor user awareness	High	High	High
Insufficient network segmentation	Medium–High	Critical	Critical

15. Overall Risk

Overall Severity: **CRITICAL**

The combination of WPA2-PSK, lack of rogue-AP detection, credential-capture opportunities, and potential MITM attacks creates a significant threat to the corporate network.

16. Conclusion

The Evil Twin attack succeeded by exploiting weaknesses in wireless authentication and user trust. The attacker created a fraudulent access point using the corporate SSID and attempted to convince employees that it was the legitimate network. Once users connected, the attacker could potentially capture credentials and perform MITM attacks.

Aircrack-ng can assist authorized security teams in identifying and analyzing wireless networks, while Wireshark can be used to examine captured traffic and identify suspicious communication patterns.

The strongest long-term solution is to move away from shared WPA2-PSK toward **WPA2-Enterprise/WPA3-Enterprise with 802.1X/RADIUS, certificate validation, MFA, WIDS/WIPS, network segmentation, continuous monitoring, and employee security awareness training**. Together, these controls provide defense-in-depth and significantly reduce the risk of future Evil Twin attacks.

Q4. Internal Wi-Fi and Web Application Penetration Testing

1. Introduction

The organization hosts a web-based employee management system that is accessible through its internal Wi-Fi network. The wireless network uses weak passwords, while the web application has weaknesses in authentication and session management.

An attacker first gains access to the wireless network, performs reconnaissance, identifies the employee management application, and exploits its vulnerabilities to escalate privileges and access confidential employee information.

The attack demonstrates that both **wireless security and web application security** must be addressed together using a defense-in-depth approach.

2. Attack Chain

The complete attack chain can be represented as:

Weak Wi-Fi Security → Network Access → Reconnaissance → Service Discovery → Web Application Discovery → Authentication Exploitation → Session Compromise → Privilege Escalation → Unauthorized Data Access

The attacker does not necessarily need to directly attack the web application from the Internet. Compromising the internal wireless network provides an initial position from which the application can be investigated.

3. Phase 1 – Wireless Network Compromise

The first weakness is the use of a weak wireless password.

Security Risk

Severity: High

A weak or shared password increases the possibility of unauthorized wireless access.

Recommended Assessment

Within an authorized laboratory environment, the analyst should identify:

- SSID
- BSSID
- Encryption type
- Authentication mechanism
- Wireless channels
- Authorized access points

Kali Linux tools such as **Aircrack-ng** can assist in wireless assessment.

Example for identifying the wireless interface:

```
iwconfig
```

Wireless networks can be observed in an authorized lab using appropriate Aircrack-ng tools.

The objective is to determine whether the wireless configuration provides adequate protection, not to attack an unauthorized network.

4. Phase 2 – Network Reconnaissance

After obtaining authorized access to the laboratory network, the tester identifies systems and services.

Nmap

```
nmap -sV <AUTHORIZED-LAB-IP>
```

This identifies:

- Open ports

- Running services
- Service versions
- Potential attack surface

For a broader authorized assessment:

```
nmap -sC -sV <AUTHORIZED-LAB-IP>
```

The results should be documented and only services within the approved scope should be assessed further.

5. Phase 3 – Web Application Discovery

Once the employee management server has been identified, the analyst examines the web application.

WhatWeb

```
whatweb http://<AUTHORIZED-LAB-URL>
```

This can identify technologies such as:

- Web server
- Programming language
- Framework
- JavaScript technologies
- CMS components

Curl

HTTP headers can be examined using:

```
curl -I http://<AUTHORIZED-LAB-URL>
```

The tester should look for unnecessary information disclosure and missing security headers.

6. Phase 4 – Web Application Scanning

Nikto can perform basic web-server vulnerability and configuration checks:

```
nikto -h http://<AUTHORIZED-LAB-URL>
```

Potential findings may include:

- Outdated components
- Misconfigured server
- Exposed files
- Missing security headers
- Dangerous configuration

Automated results should be manually validated before being reported as confirmed vulnerabilities.

7. Phase 5 – Application Reconnaissance Using Burp Suite

Burp Suite can be used to intercept and analyze HTTP requests generated by the employee management system.

The tester should examine:

- Login requests
- Session cookies
- User IDs
- Employee record parameters
- URLs
- POST parameters
- API requests
- Logout requests
- Role information

The workflow is:

Browser → Burp Proxy → Employee Application

This allows the analyst to understand how authentication and session management operate.

8. Phase 6 – Authentication Assessment

The application reportedly has poor authentication controls.

Possible weaknesses include:

- Weak passwords
- Missing MFA
- Poor login rate limiting
- Predictable authentication behavior
- Improper logout
- Failure to re-authenticate for sensitive actions

Risk

Severity: High

If authentication is compromised, an attacker may obtain access to employee accounts.

Recommendations

- Enforce strong passwords.
- Implement MFA.

- Apply login rate limiting.
- Lock or temporarily restrict suspicious authentication attempts.
- Secure password storage using strong password-hashing algorithms.
- Require re-authentication for sensitive operations.

9. Phase 7 – Session Management Assessment

Weak session management can allow attackers to reuse or manipulate authenticated sessions.

The tester should examine session cookies using Burp Suite.

Important cookie attributes include:

Secure

HttpOnly

SameSite

The analyst should also verify whether:

- Session IDs change after login.
- Sessions expire appropriately.
- Logout invalidates the session.
- Old sessions remain usable.
- Sensitive operations require a valid authenticated session.

Severity

High

Recommendation

Use secure, unpredictable session identifiers and invalidate sessions appropriately during logout and account-security events.

10. Phase 8 – Authorization and Privilege Escalation

Authentication determines **who the user is**.

Authorization determines **what the user is allowed to access**.

A major vulnerability would occur if a normal employee account can access administrator-only functionality.

For example:

Normal Employee → Employee Records

should not automatically provide:

Normal Employee → Administrator Panel

The application must perform server-side authorization checks on every sensitive request.

11. Privilege Escalation Assessment

In the authorized laboratory, the analyst can compare requests generated by different test accounts.

For example:

Account	Expected Access
Normal Employee	Own employee information
Manager/Test Elevated User	Authorized management functions
Administrator	Administrative functions

The analyst should determine whether a normal account receives access to resources that belong to a higher-privileged role.

A vulnerability is confirmed when the server incorrectly authorizes an unauthorized request.

Severity: Critical

12. Confidential Employee Data

The application contains potentially sensitive information such as:

- Employee names
- Employee IDs
- Contact information
- Job information
- Salary-related information
- Leave information
- Administrative records

Unauthorized access could result in serious privacy and organizational consequences.

13. CIA Triad Analysis

Confidentiality

Unauthorized users may access employee records.

Impact: Critical

Integrity

An attacker with elevated privileges may modify employee information or administrative records.

Impact: Critical

Availability

An attacker may disrupt the employee management application or network services.

Impact: High

Therefore, the attack can affect **all three components of the CIA triad**.

14. Risk Assessment

Vulnerability	Likelihood	Impact	Severity
Weak Wi-Fi password	High	High	High
Weak authentication	High	Critical	Critical
Poor session management	High	High	High
Broken authorization	High	Critical	Critical
Privilege escalation	Medium–High	Critical	Critical
Insufficient network segmentation	High	Critical	Critical
Lack of monitoring	Medium–High	High	High

15. Defense-in-Depth Framework

A secure architecture should be:

Employee Device

↓

WPA2-Enterprise / WPA3-Enterprise

↓

Network Access Control

↓

Employee VLAN

↓

Firewall

↓

Web Application Firewall

↓

Employee Management Application

↓

Database

Each layer should have independent security controls.

16. Wireless Security Improvements

The organization should:

1. Replace weak Wi-Fi passwords.
2. Use WPA2-Enterprise or WPA3-Enterprise.
3. Implement 802.1X/RADIUS authentication.
4. Use individual employee credentials.
5. Deploy wireless monitoring.
6. Separate employee and guest networks.
7. Use strong administrative passwords.
8. Enable MFA for wireless infrastructure administration.
9. Maintain an inventory of authorized access points.
10. Regularly audit wireless configurations.

17. Web Application Security Improvements

The application should implement:

- Strong authentication
- MFA
- Secure session management
- Server-side authorization
- Role-based access control
- Input validation
- Output encoding
- Parameterized database queries
- HTTPS
- Security headers
- Secure error handling
- Regular vulnerability scanning

Most importantly, **authorization must always be enforced on the server**. Hiding an administrator button from a normal user is not sufficient.

18. Network Segmentation

The employee application should not be placed on the same unrestricted network as every wireless device.

A recommended architecture is:

Guest Wi-Fi → Internet Only

Employee Wi-Fi → Authorized Corporate Applications

Management Network → Administrative Systems

Server VLAN → Application and Database Servers

Firewall rules should restrict communication between these zones.

19. Monitoring and Detection

The organization should monitor:

- Wireless authentication events
- Failed logins
- Successful logins
- Session anomalies
- Privilege changes
- Administrative access
- Unusual database requests
- Network scanning
- Suspicious HTTP requests

Logs should be centralized using a **SIEM** where practical.

Alerts should be generated for activities such as repeated failed authentication attempts, unusual administrator access, and abnormal data access.

20. Testing Methodology

The complete authorized penetration test should follow:

1. Planning and Scope Definition

↓

2. Wireless Assessment

↓

3. Network Reconnaissance

↓

4. Service Scanning

↓

5. Web Application Discovery

↓

6. Authentication Testing

↓

7. Session Management Testing

↓

8. Authorization Testing

↓

9. Controlled Privilege-Escalation Validation

↓

10. Risk Assessment

↓

11. Remediation

↓

12. Retesting

All testing should remain within the faculty-approved laboratory environment.

21. Recommended Security Controls

Area	Recommended Control
Wireless	WPA3-Enterprise / WPA2-Enterprise
Authentication	MFA + strong passwords
Authorization	Server-side RBAC
Sessions	Secure cookies and session expiration
Network	VLAN segmentation
Web	HTTPS + secure coding
Monitoring	SIEM + IDS/IPS
Wireless	WIDS/WIPS
Application	WAF
Database	Least-privilege access

Administration MFA + privileged access management

Testing Regular authorized security assessments

22. Overall Risk Rating

Overall Severity: CRITICAL

The combination of weak wireless security and vulnerable web-application authentication and authorization creates a serious attack chain. An attacker who obtains internal network access may be able to discover and exploit the employee management system, potentially escalating privileges and accessing confidential employee information.

23. Conclusion

The incident demonstrates how vulnerabilities across multiple layers can be chained together. The attacker begins by compromising the weak Wi-Fi network, performs reconnaissance to identify the employee management server, discovers weaknesses in authentication and session management, and then exploits authorization weaknesses to obtain higher privileges.

The organization should therefore implement **WPA2-Enterprise/WPA3-Enterprise, 802.1X authentication, network segmentation, MFA, secure session management, server-side authorization, role-based access control, WAF protection, continuous monitoring, and regular penetration testing.**

A defense-in-depth approach ensures that even if one security layer is compromised, additional controls prevent the attacker from reaching sensitive employee information or administrative systems.

Q5. Wireless Deauthentication Attack Assessment

1. Introduction

The university campus is experiencing frequent Wi-Fi disruptions during peak hours. Investigation has revealed repeated **deauthentication attacks** against wireless access points, causing legitimate users to disconnect from the network.

A deauthentication attack abuses weaknesses in wireless management-frame handling to force clients to disconnect from an access point. When performed repeatedly, it can create a **Denial-of-Service (DoS)** condition and significantly reduce wireless availability.

This assessment analyzes the attack, explains how it can be detected and safely simulated in an authorized laboratory, evaluates its impact, and recommends security controls.

2. Case Analysis

The suspected attack chain is:

Wireless Network Identification → Identification of AP/Clients → Deauthentication Frames → Client Disconnection → Reconnection Attempts → Repeated Disruption → Denial of Service

The attack primarily targets the **availability** of the wireless network rather than directly stealing confidential information.

3. What Is a Deauthentication Attack?

IEEE 802.11 wireless networks use management frames to establish and maintain connections between wireless clients and access points.

A **deauthentication frame** is normally used for a legitimate purpose: informing a client that its authentication relationship has been terminated.

The security weakness is that older wireless implementations did not always cryptographically protect these management frames. Consequently, forged management frames could potentially be accepted by clients.

An attacker can abuse this behavior by repeatedly sending fraudulent deauthentication messages, causing wireless clients to disconnect.

4. How the Attack Works

A simplified attack process is:

1. The attacker identifies the target wireless network.
2. The attacker identifies the access point's wireless information.
3. The attacker observes connected clients.
4. Forged deauthentication frames are transmitted.
5. Clients receive the frames and disconnect.
6. Clients attempt to reconnect.
7. Repeated deauthentication prevents stable connectivity.
8. Users experience a denial-of-service condition.

The attack can therefore create significant disruption even without compromising user credentials.

5. Kali Linux Tools

The assessment should be conducted **only on the faculty-approved isolated laboratory wireless network**.

Aircrack-ng

Aircrack-ng provides several tools for wireless security assessment.

A wireless interface can first be identified with:

`iwconfig`

Wireless networks in an authorized lab can then be monitored using appropriate Aircrack-ng tools.

For example:

```
sudo airodump-ng <MONITOR_INTERFACE>
```

This can display information such as:

- SSID
- BSSID
- Channel
- Encryption
- Connected clients
- Signal strength

The information can be used to identify suspicious wireless activity.

6. Detecting Deauthentication Activity

The security analyst should monitor wireless traffic and look for:

- Large numbers of deauthentication frames
- Repeated disconnect/reconnect events
- Unexpected wireless transmitters
- Sudden increases in wireless management traffic
- Multiple clients disconnecting simultaneously
- Deauthentication frames originating from unexpected devices

A sudden spike in these events is a strong indicator that the network may be experiencing a deauthentication-based attack.

7. Wireshark Analysis

Wireshark can be used to analyze authorized wireless captures.

The analyst can examine wireless management traffic and identify deauthentication frames.

A useful Wireshark filter for captured 802.11 traffic is:

```
wlan.fc.type_subtype == 0x0c
```

This can help isolate **deauthentication frames** in a suitable wireless capture.

The analyst should compare:

- Source MAC address
- Destination MAC address
- Access-point BSSID
- Number of deauthentication frames
- Timing of events

- Legitimate versus unexpected transmitters

Repeated frames from an unauthorized source may indicate malicious activity.

8. Controlled Simulation

For an academic laboratory demonstration, the attack should be simulated **only against the faculty-provided test access point and test client**.

The objective is to demonstrate:

Normal Wi-Fi connection → Controlled deauthentication event → Client disconnect → Detection in Wireshark → Recovery

The test should use a controlled environment and should stop immediately after sufficient evidence is collected.

No public, neighboring, personal, or third-party wireless networks should be targeted.

9. Identifying the Cause

The following observations can help confirm a deauthentication attack:

Observation	Possible Meaning
Multiple clients disconnect simultaneously	Possible wireless disruption
Large number of deauthentication frames	Possible deauthentication attack
Unknown transmitter generating frames	Possible rogue device
Repeated reconnect attempts	Clients being repeatedly disconnected
Normal operation resumes when suspicious activity stops	Strong indication of interference/DoS

The analyst should correlate wireless captures with access-point logs before confirming the finding.

10. Vulnerability

Unprotected Management Frames

Older wireless configurations may not adequately protect management frames.

Severity: High

An attacker can potentially forge management traffic and force clients to disconnect.

Root Cause

The primary technical weakness is insufficient protection and validation of wireless management frames.

11. Impact on Network Availability

The primary impact is **availability**.

A successful attack can cause:

- Employees/students to lose Internet access.
- Online classes to be interrupted.
- Online examinations to be disrupted.
- VoIP calls to disconnect.
- Cloud applications to become inaccessible.
- Repeated reconnection delays.
- Reduced productivity.
- Increased IT-support workload.

During peak hours, the effect can be amplified because many users depend on the same access points.

12. CIA Triad Analysis

Confidentiality

The attack itself primarily targets availability and does not necessarily expose confidential information.

Impact: Low–Medium

However, related attacks could potentially be combined with other techniques to create additional security risks.

Integrity

A deauthentication attack does not directly modify stored data.

Impact: Low–Medium

Availability

This is the primary impact because legitimate users are repeatedly disconnected.

Impact: Critical

Therefore:

Availability = Critical Risk

13. Risk Assessment

Finding	Likelihood	Impact	Severity
Deauthentication-frame abuse	High	High	High
Unprotected management frames	High	High	High

Lack of wireless monitoring	High	High	High
Rogue wireless device	Medium–High	High	High
Insufficient incident detection	Medium–High	High	High
Poor wireless configuration	Medium	High	High

Overall Risk: HIGH

14. Protected Management Frames

A major mitigation is **Protected Management Frames (PMF)**.

PMF provides protection for supported wireless management traffic and makes it more difficult to use forged management frames to disconnect legitimate clients.

Organizations should enable PMF according to their wireless infrastructure and compatibility requirements.

Where possible, security-sensitive networks should prefer configurations that require management-frame protection rather than leaving it optional.

15. WPA3

Modern wireless deployments should use **WPA3** where supported.

WPA3 provides stronger modern wireless security and works with Protected Management Frames.

Recommended options include:

- WPA3-Enterprise for enterprise environments.
- WPA3-Personal for suitable smaller deployments.
- PMF enabled according to policy.
- Updated access-point firmware.
- Replacement of obsolete wireless equipment.

16. Wireless Intrusion Detection

A **Wireless Intrusion Detection/Prevention System (WIDS/WIPS)** should be deployed to identify abnormal wireless activity.

It can help detect:

- Deauthentication attacks
- Rogue access points
- Unauthorized transmitters
- Suspicious management frames

- Wireless interference
- Unexpected changes in wireless infrastructure

Alerts should be forwarded to the security team for investigation.

17. Network Configuration Changes

The university should:

1. Enable Protected Management Frames.
2. Use WPA3 where supported.
3. Use strong enterprise authentication.
4. Separate student, staff, guest, and administrative wireless networks.
5. Deploy WIDS/WIPS.
6. Maintain an inventory of authorized access points.
7. Regularly update AP firmware.
8. Restrict access to wireless-controller administration.
9. Enable MFA for network administrators.
10. Monitor wireless logs continuously.

18. Wireless Monitoring

The security team should establish a baseline for normal wireless behavior.

Monitoring should include:

- Number of connected clients
- Deauthentication events
- Disassociation events
- Access-point health
- Channel utilization
- Signal strength
- Rogue AP detection
- Authentication failures

An unusual increase in deauthentication events should trigger an investigation.

19. Incident Response

When a deauthentication attack is detected:

Step 1

Confirm the event using wireless monitoring and packet captures.

Step 2

Identify the suspected unauthorized transmitter.

Step 3

Determine which access points and clients are affected.

Step 4

Preserve relevant logs and packet captures as evidence.

Step 5

Use authorized network-management procedures to isolate the source.

Step 6

Verify that legitimate wireless service has recovered.

Step 7

Review the wireless configuration and implement additional controls.

Step 8

Continue monitoring for recurrence.

20. Defense-in-Depth Architecture

A secure campus wireless environment should follow:

Student/Staff Devices

↓

WPA3 / WPA2-Enterprise

↓

Protected Management Frames

↓

Wireless Access Points

↓

WIDS/WIPS

↓

Network Access Control

↓

Firewall

↓

Segmented Campus Network

↓

Centralized Monitoring / SIEM

This ensures that multiple security controls work together rather than relying on a single protection mechanism.

21. Comparison of Security Approaches

Control	Purpose
WPA2-Enterprise	Individual enterprise authentication
WPA3	Modern wireless security
PMF	Protects management frames
WIDS	Detects suspicious wireless activity
WIPS	Detects and can help prevent unauthorized wireless activity
VLANs	Network segmentation
Firewall	Controls traffic between network zones
SIEM	Centralizes and correlates security events
User awareness	Reduces human-related security risks

22. Overall Security Recommendations

The university should prioritize:

Immediate

- Enable PMF where supported.
- Investigate unauthorized wireless transmitters.
- Monitor deauthentication events.
- Update AP firmware.
- Review wireless configurations.

Short Term

- Deploy WIDS/WIPS.
- Improve wireless segmentation.
- Strengthen administrator authentication.

- Centralize wireless logging.

Long Term

- Migrate suitable networks to WPA3.
- Replace outdated wireless infrastructure.
- Conduct regular wireless security assessments.
- Establish formal wireless incident-response procedures.
- Train IT staff to recognize wireless attacks.

23. Conclusion

The campus Wi-Fi disruption is consistent with a **deauthentication-based denial-of-service attack**, where repeated forged management frames cause legitimate wireless clients to disconnect from access points.

The primary consequence is a loss of **network availability**, affecting students, employees, online classes, examinations, communication, and productivity.

Kali Linux tools such as **Aircrack-ng and Wireshark** can be used in an authorized laboratory to observe wireless networks, capture traffic, identify deauthentication frames, and validate the presence of suspicious activity.

The most important defenses are **Protected Management Frames, WPA3, strong enterprise authentication, WIDS/WIPS, wireless monitoring, network segmentation, secure administration, and updated wireless infrastructure**. Together, these controls provide defense-in-depth and significantly reduce the risk of future deauthentication attacks.